

VoiceID Protocol

去中心化声纹解锁与多链钱包身份协议

白皮书 v0.1 / Draft

用户体验目标:

注册: 念 123456789 + 念 A-Z + 设置 PIN -> 创建去中心化身份

日常登录: 只念 123456789 -> 本地解锁 -> 钱包签名 -> 登录成功

安全原则: 声纹不生成私钥; 助记词由真随机数生成; 声音默认不出本地

核心结论

VoiceID 的目标不是让声音变成私钥, 而是让声音成为最友好的本地解锁入口; 真正的身份控制权来自随机生成的钱包密钥、DID、设备密钥和可验证的唯一性凭证。

发布日期: 2026-06-16 | 状态: 概念白皮书 / 实验性协议设计

目录

- 1. 摘要
- 2. 背景与问题
- 3. 产品愿景
- 4. 设计原则
- 5. 用户体验
- 6. 系统架构
- 7. 协议流程
- 8. 数据与隐私模型
- 9. 安全模型与风险
- 10. 去中心化运行模式
- 11. 开源路线图
- 12. 参考标准与资料

1. 摘要

VoicelD Protocol 是一套拟议中的开源、去中心化身份协议。它希望让用户通过念一段固定文字完成登录，例如 123456789 或 A-Z。用户不需要记邮箱、密码，也不需要等待服务器返回个性化朗读内容。

白皮书采用一个明确的安全取舍：声纹不用于生成私钥，也不用于生成 BIP39 助记词。钱包助记词必须由安全随机数生成；声纹只作为本地解锁信号和生物唯一性证明的一部分。

最终登录凭证不是音频，而是钱包签名、DID 认证、Passkey/设备密钥或可验证凭证。第三方应用不需要接触用户声音，只需要验证加密签名和必要的身份声明。

一句话说明

用户感觉自己只是“念一句话登录”；系统实际执行的是“本地声纹解锁 + 设备密钥保护 + 钱包签名动态 challenge + 可选唯一性凭证”。

2. 背景与问题

2.1 中心化登录的摩擦

传统互联网登录依赖邮箱、手机号、密码、验证码和中心化身份提供商。它们成熟、易用，但也带来账号被平台控制、跨站追踪、密码泄露、验证码劫持、用户恢复成本高等问题。

2.2 钱包登录的开放性与门槛

Web3 钱包登录把身份控制权交给用户的私钥。以太坊生态中的 Sign-In with Ethereum 使用标准消息和 nonce 让钱包地址认证链下服务 [R4]。这种方式开放、可验证，但助记词、私钥和钱包操作对普通用户仍然有门槛。

2.3 声纹登录的机会与边界

声纹是很自然的人机交互入口，尤其适合移动端、车载、老人用户、无屏设备和远程场景。但声纹不是秘密，也不是稳定的 256-bit 随机数。公开视频、语音消息、电话录音和 AI 声音克隆都会削弱声纹单独认证的安全性。

NIST SP 800-63B Rev.4 对高保证数字身份中的生物识别非常保守，并明确不允许基于声音的生物比较用于其指南定义的认证场景 [R8]。这不是对所有商业产品的法律禁令，但足以说明“声音即登录”必须有更强的加密边界。

3. 产品愿景

VoicelD 试图把“最自然的入口”和“最强的控制权”结合起来：声音负责易用，钱包负责控制，DID 负责可移植身份，去中心化注册表负责开放运行。

目标体验:

首次注册:

念 123456789

念 ABCDEFGHIJKLMNOPQRSTUVWXYZ

设置 6 位 PIN

系统生成随机 24 词助记词和多链钱包

日常登录:

念 123456789

本地验证声纹

钱包签名应用 challenge

登录成功

层次	用户看到	系统实际完成
入口层	念固定数字或字母	本地声纹验证、活体/重放检测
保护层	多数时候无感，必要时输入 PIN	设备密钥、PIN 限速、风险触发
身份层	一个 VoicelD 身份	随机助记词、多链钱包、DID
认证层	登录成功	钱包签名动态 nonce，第三方验签
唯一性层	可选证明“我是唯一人类/唯一声纹”	注册时由验证网络签发唯一性凭证

4. 设计原则

编号	原则	说明
P1	声纹不生成私钥	声音只用于本地解锁或唯一性证明，不直接决定助记词、私钥或资产控制权。
P2	助记词由安全随机数生成	24 词助记词遵循 BIP39 语义，来源应是 CSPRNG 随机熵，而不是用户声音或口令 [R1]。
P3	声音默认不出本地	第三方应用不应接收原始音频、明文声纹 embedding 或可逆生物模板。
P4	语音挑战可以固定，加密 challenge 必须动态	用户可以固定念 123456789；但应用登录必须包含 nonce、domain、时间等动态字段，防止

		签名重放 [R4]。
P5	日常登录不全网轮询声纹	唯一性检查发生在注册或恢复阶段；日常登录以本地验证和签名为主。
P6	隐私优先的 pairwise identity	同一用户可以对不同网站使用不同派生地址、DID 子身份或 site-specific nullifier，降低跨站关联。
P7	风险触发更强验证	PIN、新设备、导出助记词、高价值签名、连续失败等场景应触发额外验证。

5. 用户体验

5.1 首次注册

1. 用户打开客户端，点击“创建 VoiceID”。
2. 客户端本地生成随机 24 词助记词和多链钱包；默认不展示助记词，除非用户进入备份流程。
3. 用户念 123456789 和 A-Z，系统建立本地声纹模板。
4. 用户设置 6 位或更高强度 PIN；PIN 不应被设计成可离线无限爆破的弱加密密码。
5. 客户端创建设备密钥，并把钱包密钥加密保存在本地安全环境或加密 vault。
6. 可选：提交隐私保护的唯一性注册请求，获得 Voice Uniqueness Credential。

5.2 日常登录

日常登录尽量保持“只念一句话”的体验。用户念固定文本，客户端本地验证声纹，通过后用钱包或设备密钥对应用的动态 challenge 签名。网站只验证签名和必要凭证，不接收音频。

日常登录流程:

App 生成 nonce -> 用户念 123456789 -> 本地声纹通过 -> 钱包签名 nonce -> App 验签 -> 登录

5.3 新设备恢复

换设备是本系统的关键高风险场景。推荐体验是：用户念固定文本、输入 PIN，并通过社交恢复、阈值恢复或多设备授权恢复本地钱包。恢复网络只做限速和授权，不应接触明文助记词。

5.4 高风险操作

导出助记词、转账、绑定新设备、迁移 DID、撤销旧密钥、授权高价值应用时，应要求声纹 + PIN + 明确确认。固定数字朗读只适合低摩擦日常登录，不适合单独保护高价值资产。

6. 系统架构

- VoiceID Client
- > Voice Unlock Engine # 本地声纹验证、活体/重放检测
 - > Local Vault # 加密保存钱包、设备密钥、声纹模板
 - > Wallet & DID Module # BIP39/BIP32/BIP44、多链地址、DID
 - > Signature Module # SIWE / DID Auth / WebAuthn 风格签名
 - > Recovery Module # PIN、阈值恢复、社交恢复
- Decentralized Network
- > Registry # DID、公钥、撤销状态、凭证状态
 - > Validator Nodes # 唯一性注册、限速、阈值签名
 - > Content Network # IPFS CID 分发模型、规范、客户端版本
 - > Bridges # 可选 OIDC/Web2 桥接节点

模块	职责	不应做的事
Voice Unlock Engine	本地提取声纹、验证固定短语、检测重放/合成风险	不生成私钥；不把明文声纹发给第三方
Local Vault	加密保存钱包、设备密钥、模板和恢复材料	不允许 PIN 离线无限爆破
Wallet & DID	随机生成助记词，派生 BTC/ETH/EVM 等地址，维护 DID	不把主地址强制暴露给所有网站
Registry	记录 DID、公钥、凭证状态、撤销状态和模型版本	不存原始音频或明文声纹
Validator Network	注册时做唯一性检查、签发凭证、参与恢复限速	不成为单点中心化身份服务器
SDK / Bridge	给 dApp、App、Web2 网站提供接入	不要求网站接收用户声音

7. 协议流程

7.1 注册协议

1. Client: 生成随机 24 词助记词和主身份密钥
2. Client: 派生多链地址和 DID
3. User: 念 123456789 和 A-Z
4. Client: 生成本地声纹模板，保存在 Local Vault
5. Client: 生成 voice commitment / uniqueness request
6. Validators: 在不接收原始音频的前提下完成唯一性检查
7. Registry: 记录 DID、公钥、凭证状态、撤销状态
8. Client: 保存 Voice Uniqueness Credential

7.2 登录协议

1. App: 生成动态 challenge，包括 domain、nonce、issued_at 等字段
2. User: 念固定文本，例如 123456789
3. Client: 本地验证声纹和设备状态
4. Client: 钱包或设备密钥签名 challenge
5. App: 验证签名、公钥/DID、凭证状态
6. App: 建立会话

7.3 唯一性凭证

Voice Uniqueness Credential 用来表达“该 DID 通过了某个验证网络的唯一性检查”。它不应暴露声纹模板。面向具体网站时，可以使用 site-specific nullifier，证明同一人在同一 scope 中没有重复使用，同时避免跨站关联。Semaphore 等零知识协议展示了“证明群组成员身份并用 nullifier 防止重复”的通用思路 [R12]。

7.4 多链钱包派生

钱包助记词由随机熵生成，随后可按 BIP32/BIP44/SLIP-0044 等体系派生不同链的地址 [R2][R3][R5]。本协议不要求每个网站都看到主钱包地址；推荐为不同应用派生不同身份地址或 DID 子身份。

8. 数据与隐私模型

8.1 本地数据

```
{
  "algorithm_version": "voiceid-v0.1",
  "voice_model_version": "local-model-v1",
  "wallet_profile": "bip39-24-multichain",
  "encrypted_wallet": "local-vault-only",
  "device_public_key": "...",
  "voice_template": "encrypted-local-only",
  "pin_policy": "rate-limited"
}
```

8.2 注册表数据

```
{
  "did": "did:voice:example",
  "public_keys": [...],
  "credential_status": "active",
  "revocation_status": "active",
  "model_policy": "voiceid-v0.1",
}
```

```
"registry_signature": "..."  
}
```

注册表应避免存储原始音频、明文声纹 embedding、明文声纹模板、助记词、私钥或任何可逆生物特征。IPFS 适合分发协议文件、模型版本和不可变内容，因为 CID 基于内容寻址 [R10]；但 CID 不适合存放明文声纹库。

9. 安全模型与风险

风险	说明	缓解措施
录音重放	固定读 123456789 容易被录音	声音仅本地解锁；登录靠动态 nonce 签名；检测音频注入与重放特征
AI 声音克隆	公开音频可能训练克隆模型	设备密钥、PIN 风险触发、活体检测、异常行为风控
设备被盗	攻击者拥有本地加密 vault	本地安全硬件、PIN 限速、远程撤销、阈值恢复
PIN 爆破	低位 PIN 离线很弱	PIN 绑定设备安全模块或验证节点限速，避免公开离线爆破材料
跨站追踪	同一地址登录所有网站会暴露关联	pairwise DID、每站派生地址、site-specific nullifier
模型升级	声纹模型变化会影响验证结果	版本锁定、迁移机制、兼容测试、可回滚模型
验证节点作恶	节点可能投毒、拒绝服务或泄露数据	阈值签名、审计日志、质押/惩罚、最小化明文数据
中心桥宕机	Web2 OIDC bridge 可能不可用	多桥接节点；Web3 直接验签；本地可继续签名登录

生产级红线

VoicelD 不应宣传为“声音绝对安全”或“声音不可伪造”。生产版本必须把声纹定位为一个本地可用性因子，而不是唯一的远程认证因子。

10. 去中心化运行模式

VoicelD 的去中心化目标是减少对单一域名、单一服务器、单一身份提供商的依赖。Web3/dApp 场景可以直接使用钱包签名和链上/DID 注册表；Web2 场景可以由多个社区节点运行 OIDC bridge。

无中心 Web3 登录：
dApp challenge -> VoicelD Client 解锁 -> Wallet/DID 签名 -> dApp 验签

Web2 桥接登录:

Website -> 任一 OIDC Bridge -> VoiceID Client 签名 -> Bridge 出具 token -> Website 登录

P2P 层可使用 libp2p/Kademlia DHT 思路完成节点发现、内容路由和值查询 [R11]。但 DHT 适合 exact key routing, 不适合把全网声纹做明文近似搜索。唯一性检查应在注册阶段由专门的隐私保护验证网络完成。

11. 开源路线图

阶段	目标
M0 - 协议草案	发布白皮书、README、术语表、威胁模型、数据最小化原则
M1 - 本地原型	本地录音、声纹模板、固定短语验证、随机钱包生成、签名 demo
M2 - Wallet Login SDK	SIWE/DID Auth 接入、Web demo、移动端 demo、pairwise identity
M3 - Recovery	PIN 限速、设备恢复、社交恢复、阈值恢复、撤销机制
M4 - Unique Credential	验证节点、唯一性凭证、凭证状态、注册表、隐私评估
M5 - ZK / Nullifier	site-specific nullifier、选择性披露、匿名成员证明、反女巫场景
M6 - 审计与试点	第三方安全审计、模型偏差评估、开源社区试点、合规评估

开源治理建议

- 采用开放的 RFC 流程管理协议变更。
- 模型、客户端、验证节点、SDK 分仓库维护，但共享同一规范。
- 默认禁止上传原始音频；任何例外必须由用户明确同意，并用于研究沙盒。
- 发布安全公告、漏洞赏金、威胁模型更新和第三方审计报告。
- 明确声明实验状态，禁止早期版本承载真实大额资产。

12. 参考标准与资料

[R1] BIP39 - Mnemonic code for generating deterministic keys.

<https://github.com/bitcoin/bips/blob/master/bip-0039.mediawiki>

[R2] BIP32 - Hierarchical Deterministic Wallets. <https://github.com/bitcoin/bips/blob/master/bip-0032.mediawiki>

[R3] BIP44 - Multi-Account Hierarchy for Deterministic Wallets.

<https://github.com/bitcoin/bips/blob/master/bip-0044.mediawiki>

[R4] EIP-4361 - Sign-In with Ethereum. <https://eips.ethereum.org/EIPS/eip-4361>

[R5] SLIP-0044 - Registered coin types for BIP44. <https://github.com/satoshilabs/slips/blob/master/slip-0044.md>

[R6] W3C DID Core v1.0. <https://www.w3.org/TR/did-core/>

[R7] W3C Web Authentication Level 3. <https://www.w3.org/TR/webauthn-3/>

[R8] NIST SP 800-63B Revision 4. <https://pages.nist.gov/800-63-4/sp800-63b.html>

[R9] FIDO Alliance - Passkeys. <https://fidoalliance.org/passkeys/>

[R10] IPFS Docs - Content Identifiers and content addressing. <https://docs.ipfs.tech/concepts/content-addressing/>

[R11] libp2p Kademlia DHT specification. <https://github.com/libp2p/specs/blob/master/kad-dht/README.md>

[R12] Semaphore - Zero-knowledge group membership and nullifiers. <https://docs.semaphore.pse.dev/>

[R13] W3C Verifiable Credentials Data Model v2.0. <https://www.w3.org/TR/vc-data-model-2.0/>

免责声明

本白皮书是概念设计与开源项目启动材料，不构成安全承诺、投资建议、法律建议或生产部署建议。任何声纹、钱包、DID、恢复和唯一性验证方案都需要经过安全审计、隐私评估、合规评估和真实环境测试后，才能用于生产系统。早期版本不应承载真实大额资产。